UNIVERSITY OF EDINBURGH

COLLEGE OF SCIENCE AND ENGINEERING

SCHOOL OF INFORMATICS

INFR11158 USABLE SECURITY AND PRIVACY

May 2020

13:00 to 15:00

INSTRUCTIONS TO CANDIDATES

Answer any TWO of the three questions. If more than two questions are answered, only QUESTION 1 and QUESTION 2 will be marked.

All questions carry equal weight.

This is an OPEN BOOK examination.

Year 4 Courses

Convener: T.Komura
External Examiners: S.Rogers, S.Kalvala, H.Vandierendonck

THIS EXAMINATION WILL BE MARKED ANONYMOUSLY

1. The following passage is from Police Scotland's website on Phishing.

> Phishing is when criminals use fake e-mails or web links to obtain sensitive information about people. Information such as passwords, usernames, or bank account details.
> **How the Fraudsters Operate** A compelling reason is usually given to persuade you to go to their website or click on a link contained in an e-mail. Often the e-mail is sent under the guise that it originated from familiar names in the high street like your bank or credit card company, but others include on-line service providers, auction sites, etc. The websites often appear genuine but are, in fact designed to trick people into entering personal details.
> On entering your personal details, the criminal can gain access to your identity, take money from your bank account or infect your computer with a virus which allows them to control your system.

(a) In class we learned that people treat threats as an *externality* or an *internality*. After reading the above passage, is the reader likely to treat phishing emails as an *externality* or an *internality*? Justify your answer. [*2 marks*]

(b) Think about the lecture where we discussed what makes USec challenging. Users need the security guidance that is provided in user-facing phishing descriptions. State one of the challenges and use it to explain what makes writing a user-facing phishing description challenging, like the one above. [*3 marks*]

(c) The Police Scotland phishing page continues with this advice on what the reader can do to "take action".

> 1. Keep your browser software up-to-date.
> 2. Avoid risky sites, including supposed investment sites.
> 3. Never click on a link in an e-mail from an unknown source.
> 4. Use spam filters where possible.
> 5. Never give out your personal details, passwords or security codes via e-mail.
> 6. Don't leave personal documents lying around for anyone else to access.
> 7. Don't throw out any correspondence containing personal details without shredding first.

Select one of the pieces of advice in the above passage and state which one you selected. When considering security advice, Herley proposes the following points to decide if advice is "good" for users to follow. For your selected advice, analyze it in terms of the following three points.

- Costs - what would it cost the user to follow this advice?
- Benefits (potential) - what benefits would a user get in theory if they perfectly followed the advice?
- Benefits (actual) - what benefits will a user likely actually see? [*6 marks*]

QUESTION CONTINUES ON NEXT PAGE

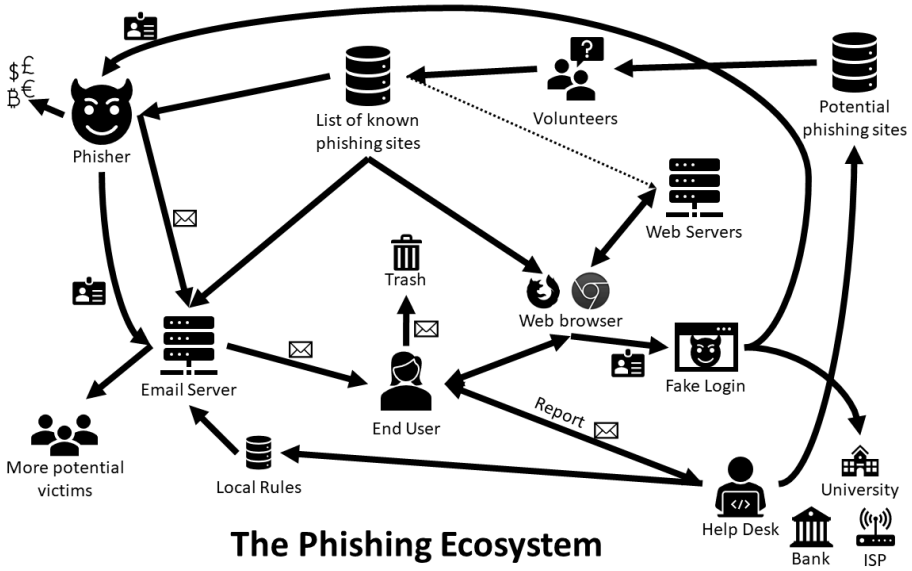

Figure 1: Slide from the phishing lecture showing the phishing ecosystem.

(d) Based on your analysis above, would you recommend that Police Scotland keep this piece of advice on their list? Why or why not? [*2 marks*]

(e) Imagine that the University of Edinburgh were to send out the following new advice and that *all* users were to correctly follow it. (Unlikely, but assume so for this question.)

"Mouse over all URLs in emails and if any look unusual do not click on it. Instead, forward the email to the University Help Desk and wait for a response."

In class we learned about how phishing protection ecosystem works. For each of the four parts of the ecosystem listed below, state how it will likely be impacted by the new advice. Consider both positive and negative impacts.

i. Help desk [*1 mark*]

ii. Email server [*2 marks*]

iii. Phisher [*2 marks*]

iv. More potential victims [*2 marks*]

(f) Write a new version of the University advice in question 1e that will reduce some of the negative impacts on the ecosystem while still encouraging users to report potential phishing attacks. Include the exact wording of your new advice in your answer, along with a short description of how it will reduce some of the negative impacts caused by the prior advice.

(The question's focus is on impacts on the ecosystem. You can assume that users will follow your advice, but you cannot assume that they know how to accurately detect phishing.) [*5 marks*]

2. Video loggers (vloggers) are people who create videos of parts of their lives and post them to online public channels such as YouTube. To make the videos they regularly record themselves in public places like shops and on public streets and parks where they may unintentionally video and audio record the people around them (bystanders).

   Bystanders have privacy rights. So often vloggers will angle their cameras upward when they are in public spaces to make sure that they respect the privacy of those around them.

Figure 2: Screenshot from Bernadette Banner's YouTube channel. She is shopping in New York city and likely has many people around her, but they are not visible because of the camera angle.

   (a) In class we learned about two definitions of privacy. State the definition that vloggers are using based on the above description and briefly explain your reasoning. [*2 marks*]

   (b) The "solution" vloggers are using is partially based on how they are thinking about privacy, in other words, it is impacted by the definition they are using.

   Imagine that vloggers used the other definition of privacy. Describe a low-tech solution, similar to angling a camera, that they could use that would support the privacy of bystanders. Briefly state why this solution supports that definition of privacy.

   Note: this question focuses on your understanding of "privacy". Simple solutions are welcome. [*3 marks*]

A new startup called Video Street Wize wants to help vloggers respect both definitions of privacy while also letting them hold their cameras in more natural positions and properly video what is happening around them. They offer vloggers a video processing software called "CutMeOut" which automatically detects faces and blurs them out or uses a filter such as adding huge emoji sunglasses to everyone, or switching out everyone's face for an emoji.

QUESTION CONTINUES ON NEXT PAGE

A huge aspect of vlogger life is interaction with their fans and often people around them. So while most bystanders might want to be blurred out, some people who are being interviewed or who are fans might want to appear. To accommodate these people, CutMeOut allows anyone to create an account on their system. They then record a short video of their face via webcam. CutMeOut uses the footage to build a model of their face for face recognition. Users can then set permissions about which vloggers can use their likeness and in what context (foreground, in a crowd, etc). Users can also select an emoji for themselves if the vlogger is using the emoji setting.

(c) In class we discussed eight privacy design strategies that system designers can use to create systems that are privacy respectful.

   i. Name one privacy design strategy that CutMeOut is **using** and describe how they are using it correctly. [*3 marks*]

   ii. Name one privacy design strategy that CutMeOut is **not using** and describe how you can tell that they are not using it. [*3 marks*]

(d) The UI of CutMeOut never asks for *explicit* permission to record and store people's facial features. But they only use the information they collect to identify people in videos and control how visible they are. No marketing, no selling, and no other use. Do CutMeOut's practices follow GDPR principles? Explain your reasoning. [*4 marks*]

(e) Imagine that CutMeOut suddenly became very popular and started being used by all sorts of organizations that record and use video; for example, the BBC. These organizations also started using it to manage privacy of bystanders in less-public places such as the inside of churches, public gatherings around sensitive topics like sexual rights, and hot dog eating competitions.

   Would this change impact your answer to question 2d? Why or why not? [*3 marks*]

(f) You have been employed by Video Street Wize as a privacy expert. Because their main clients (vloggers) are very sensitive to negative social media posts, they want to be sure that their software is perceived as privacy preserving by the general public, particularly people who regularly post on social media.

   i. Design or improve a feature for CutMeOut that provides privacy in a visible way so that random members of the public can trust that their privacy is not at risk from the software. [*3 marks*]

   ii. Describe a simple user test that Video Street Wize could run that would help them quickly learn if your feature does indeed promote confidence and trust in members of the general public. Include the name of the methodology you would use, what users in the study will be asked to do, and what information you would hope to learn from the study. [*4 marks*]

3. The Acme company has created a new web authentication system that they think will improve security and usability. When the user creates a new account, they are asked to list three user-selected secret words. When they want to log in, they are required to write a story of at least 20 words that uses all three secret words. The story is then sent to Acme's servers which scan the story to make sure all the secret words are present. It also compares the story against all prior stories the user has ever submitted to make sure it is a new unique story and differs by at least one word from all prior stories. If the story is suitably unique and contains all the words, Acme then signs the user in.

   (a) In class we learned about what makes an authentication system usable. Bonneau et al. proposed that a usable authentication system is: 1) user friendly, 2) reasonable to implement, and 3) protecting against attacks (Figure 3). Acme claims that their new system is more user friendly and more secure.

      i. State two of the metrics Bonneau et al. uses to define an authentication system as **"user friendly"**. For each metric, say if you think that Acme's system has good or bad support for that metric and explain your reasoning. [*4 marks*]

      ii. State two of the metrics Bonneau et al. uses to define an authentication system as **"protecting against attacks"**. For each metric, say if you think that Acme's system has good or bad support for that metric and explain your reasoning. [*4 marks*]

   (b) One feature of the Acme's system is that there is a natural limit to how many 20 word stories a user can write using three specific words. So users will likely need to change their secret words regularly.

   A (fictitious) researcher named Smith decided to test how many times a user is able to login successfully before needing to select new secret words. He setup an online study where a large number of users were given a new Acme account that asked them to select new secret words on first access. They were then asked to login to a research website 100 times. At any point they could select new secret words. The research subjects were paid a set amount.

   Smith found that on average users were able to log in 74 times before they needed to select new secret words. A small number of users needed to change words after only 30 stories, and a similar number were able to complete all 100 logins without needing to select new words.

      i. Would a real company likely see an average of 74 logins before employees changed their secure words? Why or why not? Make sure to mention specific aspects of Smith's study design as compared to real world working conditions. [*4 marks*]

QUESTION CONTINUES ON NEXT PAGE

ii. Similar to other authentication systems, Acme's system relies on each user's secret words being hard to guess. Imagine that Smith gave you access to the data from his study which has the columns: 1) user ID, 2) login date/time, 3) current correct secret words, 4) story submitted, 5) successful login (true or false).
Write down a research question you could realistically test using Smith's data that would address the concern about attackers being able to guess secret words. [*3 marks*]

(c) Acme's data scientists realize that they have story data from many logins of their employees and they want to know if they can use the stories to predict the mental health status of employees. To do so they partner with a University research group.

Name one principle from the Menlo Report on Ethics in Information Communication Systems. Describe how the researchers could design their study so that they correctly follow the principle. Be precise in actions they could realistically take that would align their study with your chosen principle. [*3 marks*]

(d) Acme would like to "future proof" their stories dataset so that they have explicit user consent to use it for future research projects that they think up. To do so, they would like to ask all users of their system to consent to their data being used for "research purposes" without saying what the research will be about. That way they can use it for research they have not yet thought of.

i. GDPR has 7 main principles. Name a principle and apply it to Acme's plan. [*3 marks*]

ii. Acme wants to get explicit consent from users and they decide to do so by adding the new data usage to their privacy policy.
In class we learned about the following three privacy policy designs.

Full policy - Link to a privacy policy where all the information is provided on one page.

Short structured - Short table-like structure of policy information with simple yes/no answers and links to the long full text policy.

Machine readable - Policies written in computer-friendly languages like XML, JSON, or P3P where the user can select their own client to "read" the policy for them.

Which of the above three options would you recommend Acme use to get user consent? Justify your answer. [*4 marks*]

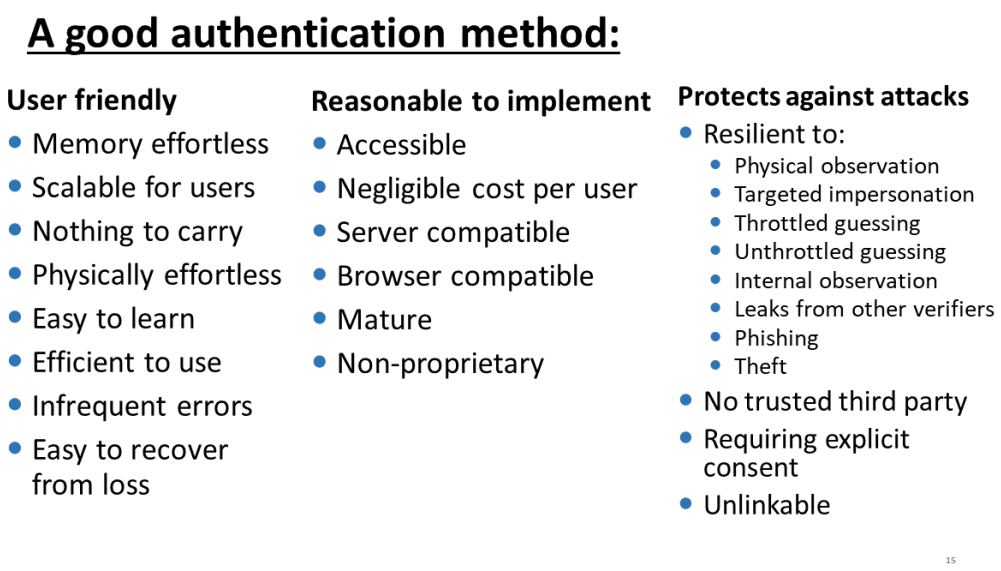

Figure 3: Lecture slide on what makes a good authentication method according to Bonneau et al.